Security Incident Report: PHI Pasted into a Public AI Chatbot

SIMULATED SCENARIO. All names, IDs and data are fictional.

Incident ID	INC-2026-0042	**Severity**	High (P2)
Category	AI data exposure (PHI sent to a public LLM)	**Status**	Contained; remediation in progress
Reported by	Developer (self-report, Duty to Report policy)	**Incident commander**	Security on-call lead
Reported	2026-10-12 09:14 EAT	**Report date**	2026-10-14 (v1.0)

1. Summary

At 09:02 EAT a developer debugging an appointment-reminder job pasted a 40-row extract from a production export into a public AI chatbot, using a personal free-tier account. The extract held names, phone numbers and reasons for visit for 38 patients. The developer realised the mistake within ten minutes and reported it to the security channel at 09:14, as the Duty to Report (Safe Harbor) policy requires.

2. Timeline

Time (EAT)	Event
09:02	Developer pastes the extract into the public chatbot (personal account).
09:12	Developer realises the data is real, stops, and screenshots what was shared.
09:14	Self-report posted to the security channel. On-call analyst acknowledges at 09:20 and opens the incident.
09:35	Developer deletes the conversation, turns off chat history and training use, and files a vendor deletion request.
09:50	Proxy and DNS logs reviewed: one session, one upload, no other consumer-AI uploads by this user in 30 days.
10:30	Scope confirmed against the source file: 38 patients; no credentials or payment data.
11:15	Data Protection Officer (DPO) and Legal engaged; notification assessment started.
Day 2	Regulator notified as a precaution, inside the 72-hour window.
Day 4	Vendor acknowledges the deletion request; patient notification letters issued.

3. Impact

38 patients' names, phone numbers and reasons for visit (health information). No credentials or financial data. No evidence of onward disclosure, but the vendor's retention and any training use cannot be fully verified, so this is treated as a confirmed disclosure to a third party. No service disruption.

4. Root cause

(1) Production data was used for debugging instead of synthetic data. (2) No control warned on or blocked uploads to consumer AI sites. (3) The approved enterprise AI tool was not well known or convenient. This is a process and tooling gap, not only an individual error.

5. Containment and remediation

Action	Owner	Status / due
Delete chat, disable training, file vendor deletion request	Developer, Security	Done (day 1)
Preserve evidence (screenshot, proxy and DNS logs)	Security	Done (day 1)
Notify regulator and affected patients	DPO, Legal	Done (day 2 / day 4)
Block consumer AI domains on corporate devices; allow approved enterprise AI	IT, Security	2026-10-19
Add DLP rule for PHI patterns on web uploads (detect mode first)	Security	2026-10-30
Short AI-use refresher and 'how to report' training	Security, HR	2026-11-01
Synthetic test-data generator; no production extracts in dev	Engineering lead	2026-11-15

6. Notification and compliance

Safe Harbor applied: prompt, honest self-report, so no disciplinary action. The DPO assessed the event as a personal data breach involving health data. Notifications were made under the applicable data-protection law (Legal to confirm requirements for the jurisdiction). Patients were told in plain language what happened and who to contact. Entry added to the breach register.

7. Lessons learned

Self-reporting meant action began 12 minutes after the paste, so keep Safe Harbor visible. Make the safe path (approved AI tool, synthetic data) easier than the unsafe one. Track: time to report, time to contain, consumer-AI uploads blocked per month.

Prepared by: Ian Muzai| Reviewed by: [DPO] | Distribution: need-to-know